



Instituto Politécnico Nacional
Escuela Superior de Cómputo



Ingeniería en Sistemas Computacionales
Academia de Sistemas Distribuidos

Unidad de Aprendizaje:
Gobierno de TI | Computer Security

Tarea 19: “Elaboración de Reportes”

Luis Andrés Contla Mota

2022630540

6CV4

Profesor:

MBA. Rodrigo Ojeda Santillán

Reporte Ejecutivo de prueba de penetración

SecureBank Financial Services - Periodo
Q1 2024

Cliente: SecureBank Financial Services

Periodo: 15 Febrero - 15 Marzo 2024 (4 semanas)

Evaluador: Cyber Security Solutions Inc.

Tipo de Prueba: Grey-box Testing (credenciales usuario bajo privilegio)

Fecha reporte: 15 Marzo 2024.

Resumen Ejecutivo

Se condujo evaluación de seguridad integral en infraestructura crítica de SecureBank Financial Services. Durante las 4 semanas de pruebas se identificaron vulnerabilidades que permiten acceso no autorizado a datos de clientes y ejecución de código remoto en servidores críticos. Nivel de riesgo global CRÍTICO. Se requiere remediación inmediata.

Resumen de Hallazgos.

ID	Vulnerabilidad	Severidad	CVSS v3.1
V-001	SOL injection, portal de login	Alta	9.8
V-002	Remote code execution, API REST	Media	7.5
V-003	Información sensible expuesta	Baja	3.7

Alcance de la prueba

Sistemas evaluados

Sistema	Descripción	IP	Estado
Portal cliente web	Aplicación web de clientes	192.168.1.50	Evaluable
API REST Backend	Servicios back-end críticos	192.168.1.51	Evaluable
Mail server	Servicio correo corporativa	192.168.1.52	Evaluable
Firewall perimetral	Palo Alto networks	192.168.1.1	Evaluable

Exclusiones: sistemas de producción PCI-DSS, datacenter secundario disaster recovery.

Metodología utilizada

Frameworks: OWASP Testing guide v4.2, NIST SP 800-115, PTES

Fase	Descripción	Duración
Reconocimiento	OSINT pasivo, DNS enumeration, information gathering	3 días
Escaneo	Nmap active scanning, Nessus vulnerability scan	5 días
Enumeración	Banning, versioning, web application mapping	5 días
Explotación	Vulnerability exploitation, credential harvesting.	7 días
Post-Explotación	Lateral movement, privilege escalation, data discovery	3 días
Documentación	Análisis impacto, validación hallazgos, redacción reporte.	3 días.

Herramientas: Nmap 7.93, Burp suite professional 2021.1, Metasploit Framework, SQLmap 1.7.2, Wireshark 4.2, John the Ripper, N.ATO 2.1.4.

Hallazgos detectados

[V-001] Sql injection - Portal de login

Ubicación: <https://portal.securebank.local/login.php> (parámetro: username)

Severidad: ALTA - CVSS 9.8 (Crítico)

Descripción: la aplicación no valida la entrada del usuario antes de pasarla a sentencia SQL. Payload: admin' OR '1'='1' -- elude autenticación completamente.

Impacto: Acceso no autorizado a cuentas, robo de 50,297 registros cliente (nombre, email, SSN, no. cuenta, balance).

Evidencia: Acceso exitoso como administrador sin contraseña. Descarga completa de registros completada en 3 minutos.

[V-002] Remote code execution - API REST

Ubicación: POST /api/v1/reports (parámetro: filename)

Severidad: Media - (CVSS 7.5 (Alto))

Descripción: El servidor acepta upload de archivos sin validar extensión. Se subió shell.php ejecutado como usuario www-data.

Impacto: Ejecución de código arbitrario, access filesystem, extracción de credenciales de base de datos, lateral movement.

Evidencia: shell.php?cmd=id retornó uid=33 (www-data). Archivo /var/www/config/database.php, expuso user:securebank-app, pass: \$772.?

[V-003] Información sensible Expuesta

Ubicación: robots.txt, comentarios HTML en código fuente.

Severidad: Baja - (CVSS 3.7 (Bajo))

Descripción: robots.txt lista directorios administrativos. Comentarios HTML revelan versiones de software ligado y endpoints deprecados.

Impacto: Facilita reconocimiento, mapeo de arquitectura, identificación de versiones vulnerables de software.

Evidencia: robots.txt: Disallow /admin/, /api-test/, /backup/.

Dirección /backup accesible sin autenticación con dumps SQL de 2023.

Recomendaciones

Prioridad	Vulnerabilidad	Acción Recomendada	Plazo
Critico	SQL injection	Prepared statements, input validation, WAF con reglas	24-48 hrs
Critico	RCE en API	Whitelist extensiones permitidas, deshabilitar ejecución PHP en /uploads/.	24-48 hrs
Critico	credenciales expuestas	Proteger contraseñas MySQL, auditar logs de acceso, adoptar password manager.	24 hrs
Alto	Info sensible	Actualizar robots.txt, eliminar comentarios HTML, proteger /backup/	1-2 sem
Alto	SDLC	Integrar SAST/DAST en CI/CD, capacitar equipo en OWASP Top 10	2-4 sem